

የውስጥ-ለውስጥ ማስታወሻ
Inter-Office Memorandum

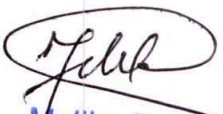
Date: November 12, 2025

To: All Vice Presidents

All Chiefs

All Directors

From: Chief Executive Officer


Melika Bedri
Chief Executive Officer

Subject: Issuance of Cyber Security Procedure

The Executive Management Committee, dated November 11, 2025 under its minute no. EMC/179/2025 has deliberated and approved Cyber Security Procedure.

This is, therefore, to formally communicate to you the attached approved Cyber Security Procedure for your proper implementation and compliance.

Please make sure that all concerned employees under your jurisdiction have received the Procedure so as to implement without fail.



CYBERSECURITY PROCEDURE

2025



VISION, MISSION, AND CORE VALUES

Vision

"To be the Leading Sharia Compliant and All - Inclusive Bank in Africa by the Year 2030"

Mission

"We are committed to demonstrate Sharia principles in harnessing sustainable financial resources, being a model of excellence through digitalization and competent work force to realize our stakeholder's values"

Core Values

- Integrity
- Upholding Sharia' h principles
- Inclusiveness
- Service Excellence
- Innovativeness
- Professionalism
- Social Responsibility



[Handwritten signature]

TABLE OF CONTENT

PART I INTRODUCTION.....	1
1.1 Preamble.....	1
1.2 Short Title.....	2
1.3 Scope of Application	2
1.4 Objectives.....	2
PART-II: AUTHORITY AND RESPONSIBILITY	3
2.1. Chief Executive Officer (CEO).....	3
2.2. Chief Information Officer (CIO).....	3
2.3. Security Manager	3
2.4. SOC Analysts.....	4
2.5. Cyber Security Engineer	4
2.6. Systems Administration	4
2.7. IT Infrastructure	5
2.8. Head office, Districts and Branch officers.....	5
2.9. Third Parties	5
PART-III: CYBER SECURITY PROCEDURE.....	5
3.1. Asset Management	5
3.2. Identity & Access Management.....	6
3.3. Cryptographic Controls	7
3.4. Operations Security.....	8
3.5. Logging, Monitoring & Security Event Management.....	8
3.6. Network Security & Segmentation	10
3.7. Secure Configuration & Hardening.....	11
3.8. Vulnerability & Patch Management.....	11
3.9. Backup & Recovery Security	12
3.10. Change Management.....	13
3.11. Supplier & Third-Party Security.....	14
3.12. Cloud Security Controls.....	15
3.13. Data Protection & Privacy.....	15
3.14. Physical & Environmental Security	16



WA

3.15.	Application Security & Secure Development	17
3.16.	Email, Web Security & DLP	18
3.17.	Business Continuity & Cyber Resilience	18
3.18.	Endpoint, Server & User Device Security	19
3.19.	Secure Remote Access Controls	20
3.20.	Security Awareness, Training & Competency	20
3.21.	Log Integrity & Anti-Tampering Controls	21
3.22.	Audit Logging Requirements	21
3.23.	Information Security & Governance	22
3.24.	Human Resources Security	23
3.25.	Software Asset & License Management	23
3.26.	Secure Disposal & Media Handling	24
3.27.	Segregation of Duties (SoD)	24
3.28.	Penetration Testing & Red Teaming	25
3.29.	Application Whitelisting & Execution Control	25
3.30.	Insider Threat Management	26
3.31.	Secure Coding & Software Composition Analysis (SCA)	26
3.32.	Capacity & Performance Management	27
3.33.	Security Metrics & KPI Reporting	27
3.34.	Privacy Impact Assessment (PIA)	28
3.35.	Data Retention, Archiving & Legal Hold	28
3.36.	Audit & Compliance Testing	29
	PART-IV: PROCEDURE MANAGEMENT AND EXCEPTIONS	30
	ANNEX I - DEFINITION OF TERMS	31
	ANNEX II – ACRONYMS	37



Handwritten signature/initials.

PART I INTRODUCTION

1.1 Preamble

Whereas, ZamZam Bank S.C. relies on modern information systems, digital channels, and interconnected technologies to deliver secure and efficient financial services;

Whereas, the Bank's critical information assets including Core Banking, digital banking platforms, payment systems, databases, networks, cloud environments, and datacenter infrastructure must be protected against cyber threats, unauthorized access, data breaches, and operational disruptions;

Whereas, cyber risks are increasing in scale and complexity, requiring strong preventive, detective, and responsive security controls to safeguard the confidentiality, integrity, availability, and authenticity of information;

Whereas, ZamZam Bank is committed to complying with the National Bank of Ethiopia's directives, applicable data protection laws, and international standards such as ISO/IEC 27001 and the NIST Cybersecurity Framework;

Whereas, the Bank's cybersecurity responsibilities are shared across the Information Security team, SOC Analysts, Security Engineers, System and Network Administrators, and Application Support staff;

Now, therefore, This Cybersecurity Procedure is hereby issued to establish standardized cybersecurity practices, define roles and responsibilities, ensure compliance with regulatory and international security requirements, and strengthen the Bank's resilience against cyber threats. It shall apply to all employees, systems, processes, and third parties accessing or managing ZamZam Bank information assets.



A handwritten signature in blue ink, appearing to be 'M.A.', located at the bottom right of the page.

1.2 Short Title

This document may be cited as the "Cybersecurity Procedure of ZamZam Bank S.C."

1.3 Scope of Application

This Procedure applies to all information systems, digital services, infrastructure components, networks, applications, databases, data centers, cloud services, third-party integrations, and user accounts owned or managed by ZamZam Bank. It covers the Core Banking System, digital banking channels, ATM/POS acquiring and issuing platforms, the payment switch, the enterprise network, datacenter infrastructure, DR site, security technologies, endpoints, and all internal banking applications.

It applies to all employees, SOC personnel, Security Engineers, System Administrators, Network Engineers, Application Support staff, contractors, consultants, and third-party vendors who interact with ZamZam Bank's information systems or have security responsibilities within the Bank's environment.

1.4 Objectives

The objectives of this Cybersecurity Procedure are to:

- Translate the Bank's Cybersecurity and Information Systems Policies into clear, actionable operational steps.
- Ensure consistent implementation and monitoring of cybersecurity controls across all Bank systems and processes.
- Protect the confidentiality, integrity, availability, and authenticity of ZamZam Bank's information assets.
- Strengthen the Bank's ability to prevent, detect, respond to, and recover from cyber threats and incidents.



- Define roles and responsibilities for all staff involved in cybersecurity activities, including SOC, Security Engineers, System and Network Administrators, IT Infrastructure and Application Support.
- Align the Bank's cybersecurity practices with ISO/IEC 27001, NIST and NBE regulatory requirements.
- Reduce cybersecurity risks, support audit and compliance needs, and enhance the Bank's overall cyber resilience.

PART-II: AUTHORITY AND RESPONSIBILITY

2.1. Chief Executive Officer (CEO)

- Approves the Cybersecurity Procedure and any amendments.
- Receives reports on critical cybersecurity incidents.

2.2. Chief Information Officer (CIO)

- Oversees execution and operationalization of all cybersecurity activities.
- Ensures effective coordination among all IT divisions (SOC, Systems, Networks, Infrastructure, Applications, Security).
- Enforces compliance with the Cybersecurity Procedure across all units.
- Approves major changes involving security architecture and critical controls.
- Ensures IT teams work cohesively to protect the Bank's environment.

2.3. Security Manager

- Leads the Bank's cybersecurity operations and manages the SOC.
- Oversees threat intelligence, vulnerability management, access governance, and risk assessments.
- Coordinates cybersecurity audits and compliance activities.
- Has authority to activate the Incident Response Team and initiate containment.
- Escalates critical issues to the CIO and enforces urgent corrective actions.



[Handwritten signature]

2.4. SOC Analysts

- Monitor SIEM dashboards and security tools in real time.
- Perform initial alert triage and categorization.
- Conduct deeper investigations and correlation of logs.
- Escalate confirmed incidents to Manager IT Security/ senior SOC staff or incident response teams.
- Validate indicators of compromise (IOCs).
- Assess incident scope, impact, and recommended containment steps.
- Execute containment actions as authorized.

2.5. Cyber Security Engineer

- Configures, deploys, and maintains security technologies (SIEM, EDR, IDS/IPS, DLP, PAM, encryption platforms).
- Tunes detection rules and improves alert accuracy.
- Conducts security health checks across the environment.
- Conduct vulnerability assessments and penetration testing to identify weaknesses.
- Supports containment, remediation, and secure system redesign.
- Coordinates closely with Systems and Network teams during incidents.

2.6. Systems Administration

- Install, configure, and maintain servers, operating systems, and enterprise applications.
- Apply secure baselines and hardening configurations.
- Implement patches and updates promptly.
- Perform regular system backups, recovery tests, and disaster recovery procedures
- Maintain system audit logs and support SOC investigations.



A handwritten signature or mark in blue ink, consisting of a vertical line with a small hook at the top and a horizontal line at the bottom.

- Assist with forensic imaging and evidence preservation.
- Quarantine compromised servers and assist in recovery procedures.

2.7. IT Infrastructure

- Enforce secure network architecture and segmentation.
- Implement and review firewall rules and routing policies.
- Manage VPN security and secure connectivity for HO, branches, and DR.
- Support network-level containment actions during incidents.

2.8. Head office, Districts and Branch officers

- Ensure accurate and compliant data entry into banking systems.
- Report anomalies or suspicious activities promptly.
- Cooperate fully during investigations or incident response.

2.9. Third Parties

- Must comply with the Bank's cybersecurity and contractual requirements.
- Follow Bank guidelines for access control, remote connectivity, and data handling.
- Report security incidents affecting the Bank promptly.

PART-III: CYBER SECURITY PROCEDURE

3.1. Asset Management

Purpose

To maintain accurate visibility and classification of all information assets across the Bank, ensuring proper protection based on sensitivity and criticality.

Procedure



The Bank maintains a centralized asset repository covering hardware, software, cloud services, APIs, databases, virtual machines, firewall rules, network segments, and privileged accounts.

System Administrators, Network Engineers, and Security Engineers submit quarterly inventory updates. The Security Manager conducts reconciliation to ensure completeness.

Each asset is classified using categories such as Confidential, Restricted, Internal, or Public, depending on sensitivity. Business units owning sensitive systems (e.g., Core Banking) are responsible for approving classification levels.

Unauthorized or unregistered assets discovered during scans are immediately isolated pending investigation by the Security Manager.

Roles

- Security Manager: Maintains asset classification and CMDB.
- System/Network Engineers: Provide updates and corrections.
- SOC Analysts: Alert on unrecognized assets.

3.2. Identity & Access Management

Purpose

To regulate authentication, authorization, credential lifecycle management, privileged access, and monitoring to prevent unauthorized access.

Procedure

Access to systems is granted only through formally approved requests submitted via the Bank's communication channels. Every user must have a unique ID; shared accounts are prohibited except where justified and approved by CIO/ Head of IS department.



A handwritten signature in blue ink, appearing to be 'V.A.' or similar, located at the bottom right of the page.

Multi-factor authentication (MFA) is enforced for privileged users, remote access, and sensitive applications. Password policies follow strong entropy requirements and periodic rotations.

Privileged access is managed exclusively via the PAM system. All administrative sessions are recorded and monitored. Time-bound access requires explicit justification and approval.

Quarterly access reviews are performed by System Administrators for IT systems, , by Application Support for business applications, IT Infrastructure and other IS unit as applicable . The Security Manager oversees these reviews to ensure least privilege is consistently applied.

Terminated or transferred employees must have their accounts disabled within a day of HR notification.

Roles

- System Administrator: Implements provisioning.
- Security Manager: Consult with IS Head for approval of privileged access.
- SOC: Monitors login anomalies.

3.3. Cryptographic Controls

Purpose

To protect data confidentiality and integrity through approved encryption mechanisms.

Procedure

Security Engineers ensure that sensitive data is encrypted using approved algorithms. Cryptographic keys must be generated, stored, rotated, and destroyed securely through a managed key lifecycle. Private keys must not be stored in plaintext or transmitted through email.



Database encryption, application level encryption, and full-disk encryption are enforced for critical servers. Certificates are monitored, renewed, and revoked by the Security Engineer.

Any exception to cryptographic requirements requires CIO approval.

Roles

- Security Engineer: Manages PKI and crypto lifecycle.

3.4. Operations Security

Purpose

To ensure secure, stable, and controlled operation of IT services.

Procedure

The Bank implements secure change management, configuration management, logging, capacity planning, malware protection, and operational monitoring.

System logs, job schedules, and console access are periodically reviewed. Unauthorized software is prohibited. System Administrators apply updates during approved maintenance windows.

Roles

- System Administrator: Executes operational tasks.
- SOC: Monitors operational anomalies.

3.5. Logging, Monitoring & Security Event Management

Purpose

To ensure that all critical systems, applications, databases, and network devices generate complete, accurate, tamper-resistant logs that enable effective monitoring,



detection of security anomalies, and forensic investigation. Logs serve as the foundation of the SOC's monitoring and threat detection capabilities.

Procedure

All systems classified as production must forward logs to the Bank's centralized SIEM platform. This includes authentication logs, system events, firewall decisions, IDS/IPS alerts, application and API logs, and audit trails from business applications (e.g., Core Banking, Digital Banking, Card Systems).

System Administrators are responsible for enabling operating system audit policies, ensuring logging agents remain active, and resolving ingestion failures. Network Engineers configure firewall, VPN, and network devices to send logs to designated SIEM collectors. Application Support in consultation with system team ensures business applications generate structured logs that include timestamps, user identifiers, and event context.

SOC Analysts conduct continuous monitoring of SIEM dashboards. The analysts perform daily health checks on log ingestion and detect anomalies such as missing logs, unusual spikes in events, or signs of tampering. The analysts correlate logs from multiple systems to identify sophisticated attacks. The analysts validate advanced threats and support forensic reconstruction.

The Security Manager ensures log retention policies are followed as per best practices and standard and depending on regulatory requirements. Logs must be protected against alteration, unauthorized access, and deletion.

Roles

- SOC Analysts: Monitor, triage, correlate, and escalate events.
- Security Engineer: Manage SIEM configuration and rule tuning.
- System/Network Admins: Ensure logs are generated and forwarded.
- Security Manager: Oversees log governance and retention.



3.6. Network Security & Segmentation

Purpose

To ensure the Bank's networks are designed, segmented, controlled, and monitored in a way that minimizes unauthorized access, lateral movement, and exposure to cyber threats.

Procedure

Network Engineers maintain a hierarchical network architecture that separates critical banking domains from less critical ones. Core Banking, Digital Banking, Card Systems, and Payment Switch environments reside in isolated network zones protected by firewalls, VLANs, and access control lists.

All firewall rule changes must be formally requested, justified, risk-assessed, approved by the Security Manager, and implemented during controlled windows. Rules must be specific, time-bound where appropriate, and follow least privilege principles.

The Security Engineer and Network Engineer jointly conduct quarterly firewall reviews to identify redundant, unused, or risky rules. Immediate removal is enforced for rules that are no longer required.

Intrusion Detection/Prevention Systems (IDS/IPS) are deployed at network boundaries and between critical segments. SOC Analysts monitor their alerts. VPN connections must enforce MFA, encryption, and secure configurations.

Roles

- Network Engineer: Implements segmentation & firewall rules.
- Security Engineer: Maintains IDS/IPS, reviews rules.
- SOC: Monitors network alerts.
- Security Manager: Approves exceptions and risky rule changes.



A handwritten signature in blue ink, appearing to be 'M.A.', located at the bottom right of the page.

3.7. Secure Configuration & Hardening

Purpose

To ensure all systems, including servers, endpoints, databases, and network devices, are configured securely using standardized baselines that minimize attack surfaces.

Procedure

System Administrators apply industry recognized hardening templates (e.g., CIS Benchmarks or DISA STIGs) for Windows, Linux, AIX, and virtualization hosts. Hardening includes disabling unnecessary services, enforcing strong authentication, limiting administrative shares, enabling auditing, applying encryption, and restricting remote access.

Network Engineers must harden routers, switches, firewalls, and wireless controllers by disabling insecure protocols, enforcing secure management channels (SSH, HTTPS), and enabling configuration integrity monitoring.

The Security Engineer audits baseline compliance using scanning tools and reports deviations to the Security Manager for remediation. Deviations require documented approval and must be justified business needs.

Roles

- System Admin: Implements OS hardening.
- Network Engineer: Secures network device configurations.
- Security Engineer: Performs compliance checks.
- Security Manager: Recommend IS head or Approves exceptions as applicable.

3.8. Vulnerability & Patch Management

Purpose

To systematically identify, assess, prioritize, and remediate vulnerabilities that could be exploited to compromise Bank systems.



A handwritten signature in blue ink, appearing to be 'M.A.' or similar, located at the bottom right of the page.

Procedure

The Security Engineer performs weekly automated vulnerability scans across all infrastructure, servers, firewalls, databases, and cloud instances. Results are validated, categorized, and prioritized by the Security Manager based on business criticality and exploitability.

Remediation timelines:

- Critical vulnerabilities: Fix immediately
- High severity: Fix in a day
- Medium severity: Fix within 1–5 days
- Low severity: Fix in normal maintenance cycles

System Administrators apply patches during approved maintenance windows. Emergency patching requires CIO approval.

SOC Analysts observe for exploitation attempts or scanning activities targeting unpatched systems.

Roles

- Security Engineer: Scanning and validation.
- System Admin: Patch deployment.
- Security Manager: Prioritization and compliance.
- SOC: Monitor exploitation attempts.

3.9. Backup & Recovery Security

Purpose

To ensure that data, systems, and configurations can be restored securely and reliably in the event of a disaster, corruption, ransomware attack, or system failure.



A handwritten signature in blue ink, appearing to be 'H. A.', located at the bottom right of the page.

Procedure

System Administrators ensure all critical systems and databases follow the Bank's backup schedule, including full, incremental, and replica backups. Backups must be encrypted, tested, and stored both onsite and offsite, including in the DR environment.

Backup success logs are reviewed daily by System Administrators and monitored by SOC for anomalies. Critical backups are tested quarterly through restore drills supervised by the Security Manager.

Access to backup repositories is restricted via privileged access controls. Backup devices must be isolated from general networks to mitigate ransomware attacks.

Roles

- System Admin: Performs backups and restore tests.
- Security Manager: Oversees DR readiness.
- SOC: Monitors for tampering or anomalies.

3.10. Change Management

Purpose

To ensure all changes to IT systems are controlled, tested, evaluated for security impact, and approved before implementation.

Procedure

Any change whether related to application updates, configuration modifications, firewall rules, patches, or new integrations must follow the formal Change Management Procedure.

A Change Ticket Owner submits a change request describing scope, purpose, risk, rollback plan, and affected systems. The Security Manager assesses cybersecurity risks; submit for IT head/CIO for approval or rejections.



A handwritten signature in blue ink, appearing to be 'MA' or similar, located to the right of the page number.

Changes to critical systems require CIO approval and SOC monitoring during implementation windows.

Roles

- CTO (Change Ticket Owner): Creates request.
- Security Manager: Security impact assessment.
- CIO: Approves high-risk changes.

3.11. Supplier & Third-Party Security

Purpose

To ensure that third-party vendors handling Bank data or systems follow security standards that protect the Bank from supply chain risk.

Procedure

Before onboarding any vendor, a third-party risk assessment is conducted by the Security Manager. Vendors must demonstrate security maturity (ISO 27001, SOC2, PCI DSS, or equivalent).

Access provided to vendors must be strictly limited, time-bound, and monitored via PAM. SOC monitors vendor activity logs for anomalies. Contracts must include confidentiality, incident reporting, and audit clauses.

Vendor systems connected to the Bank must comply with the Bank's security controls. Non-compliant vendors must be remediated or disconnected.

Roles

- Security Manager: Performs vendor security assessments.
- System/Network Admin: Enforces access boundaries.
- CIO: Approves high-risk vendors.



A handwritten signature in blue ink, located at the bottom right of the page.

3.12. Cloud Security Controls

Purpose

To ensure secure deployment, monitoring, access, and governance of cloud-based services or workloads.

Procedure

Cloud services may only be used after approval from the CIO and Security Manager. Cloud environments must enforce strong identity management, encryption, logging, network isolation, and monitoring.

Security configurations must follow zero trust principles. Cloud logs must be integrated into SIEM. Any public cloud exposure must be risk-assessed.

Roles

- Security Engineer: Cloud security configuration.
- SOC: Monitors cloud logs.

3.13. Data Protection & Privacy

Purpose

To ensure the Bank protects personal, financial, and sensitive data throughout its lifecycle and meets regulatory and Sharia-compliance requirements.

Procedure

Data must be classified, processed lawfully, transmitted securely, stored safely, and disposed of in a controlled manner. Access to sensitive data must be restricted.

Data Loss Prevention (DLP) systems monitor and prevent unauthorized transmissions. Confidential data must only be shared with authorized parties following documented procedures.



A handwritten signature in blue ink, appearing to be 'M.A.' or similar, located at the bottom right of the page.

Roles

- **Security Manager:** Ensure data protection program are emplaced.

3.14. Physical & Environmental Security

Purpose

To ensure that physical access to the Bank's information systems, datacenter, network infrastructure, and sensitive environments is controlled, monitored, and restricted to authorized individuals only, protecting systems from damage, unauthorized access, tampering, or environmental threats.

Procedure

Access to the datacenter, DR site, UPS room, network distribution rooms, and CCTV control rooms is strictly limited to authorized personnel. The Security Manager maintains and reviews access lists quarterly.

Visitors, including vendors and contractors, must follow controlled entry procedures, be escorted at all times, and sign access logs. SOC Analysts monitor CCTV feeds, access logs, and motion alerts 24/7 to detect physical anomalies.

Environmental controls including temperature, humidity, fire suppression, water leakage sensors, and power redundancy are monitored continuously. Alerts are forwarded to both SOC and Facility Management. System Administrators check physical server health indicators weekly.

Unauthorized access attempts must trigger immediate alerts and automatic escalation to the Security Manager and CIO.

Roles

- **Security Manager:** Approves access, conducts reviews.
- **SOC Analyst:** Monitors surveillance and alarms.
- **System Admin:** Performs physical equipment inspection.



A handwritten signature in blue ink, appearing to be 'M.A.' or similar, located at the bottom right of the page.

- Facilities Team: Maintains physical conditions.

3.15. Application Security & Secure Development

Purpose

To ensure all applications including Core Banking, Digital Banking, payment systems, mobile apps, and in-house systems are designed, developed, tested, and maintained using secure development principles.

Procedure

The Security Manager enforces a secure development lifecycle (SDLC) framework. Application Support and development teams must incorporate threat modeling, security requirements, code review, and vulnerability testing at each stage. Static and dynamic application security testing (SAST/DAST) tools must be used during development.

Changes to applications must undergo security assessment before deployment. Injection, authentication, session, and authorization controls must be validated. APIs must enforce rate limiting, authentication, and input validation.

For third-party or vendor applications, the Security Engineer performs penetration tests and vulnerability assessments before acceptance.

Roles

- Security Engineer: Performs application security testing.
- System Administration: Implements secure configurations.
- Vendor/Developer: Fixes weaknesses identified.
- Security Manager: Approves security readiness.



A handwritten signature in blue ink, appearing to be 'M. A.', located at the bottom right of the page.

3.16. Email, Web Security & DLP

Purpose

To protect the Bank from phishing, malware, data exfiltration, and unauthorized disclosure through email and web channels.

Procedure

The Security Engineer configures email gateways to enforce SPAM filtering, malware scanning, DMARC/DKIM/SPF policies, and anti-phishing controls. Suspicious messages are quarantined, and SOC Analysts review quarantined items daily.

Data Loss Prevention (DLP) rules monitor outbound emails, uploads, and file transfers for protected information such as customer data, financial information, and credentials. Violations trigger alerts to SOC, and serious violations escalate to the Security Manager and HR.

Roles

- Security Engineer: Configures email/web/DLP policies.
- SOC Analysts: Monitor violations and phishing attempts.
- Users: Must report suspicious emails immediately.

3.17. Business Continuity & Cyber Resilience

Purpose

To ensure the Bank can continue essential operations, maintain data integrity, and resume services following cyberattacks, disasters, or major disruptions.

Procedure

The Security Manager ensures cybersecurity requirements are embedded into Business Continuity Plans (BCP) and Disaster Recovery (DR) plans.



[Handwritten signature]

Annual DR drills are conducted. Failover/fallback procedures must follow documented steps validated by System Administrators and Network Engineers.

Backups must be secured and tested using actual restore operations. Cyber incident scenarios (e.g., ransomware, data corruption) must be part of BCP tests.

Roles

- Security Manager: Oversees cyber continuity.
- System Admin: Executes DR failover.
- SOC Analyst: Monitors replication & integrity.
- CIO: Approves DR activation.

3.18. Endpoint, Server & User Device Security

Purpose

To prevent compromise, malware, unauthorized access, and data loss from endpoints and servers.

Procedure

All endpoints (desktops, laptops, tablets, mobile devices) must run updated anti-malware, endpoint detection and response (EDR), and host-based firewalls.

System Administrators deploy standard images hardened using CIS Benchmarks. Unauthorized applications are blocked using allow lists.

Local admin privileges are prohibited unless explicitly approved by Security Manager. SOC Analysts monitor EDR alerts for suspicious activity.

Roles

- System Admin: Ensures secure endpoint configuration.
- Security Engineer: Manages EDR and policies.
- SOC: Monitors alerts.



3.19. Secure Remote Access Controls

Purpose

To secure remote access connections and prevent unauthorized or unsafe access into Bank systems.

Procedure

Remote access is permitted only through Bank-managed VPN solutions and should be approved by CIO/IS head. MFA is mandatory. Split tunneling is prohibited. Administrative access from external networks must be performed through controlled jump servers with PAM enforcement.

Remote sessions must be recorded and monitored by SOC. Connections from risky locations require additional approvals. Vendor remote access must be time-bound and supervised.

Roles

- Network Engineer: Implements VPN configurations.
- Security Manager: Approves remote access in consultation with CIO/IS head.
- SOC: Monitors activity.

3.20. Security Awareness, Training & Competency

Purpose

To ensure staff understand cyber risks, their responsibilities, and follow secure behaviors in daily operations.

Procedure

The Security Manager runs mandatory annual cybersecurity training covering phishing, password hygiene, data protection, safe browsing, and incident reporting. SOC may conduct simulated phishing campaigns.



[Handwritten signature]

Role-based training is provided for privileged users, SOC Analysts, System Administrators, and developers. Training completion is tracked and non-compliance escalated to HR.

Roles

- Security Manager: Ensure training programs are implemented.
- SOC: Executes phishing simulations.
- HR: Tracks training for its implementation and compliance.

3.21. Log Integrity & Anti-Tampering Controls

Purpose

To ensure security logs cannot be altered, deleted, or manipulated.

Procedure

Logs must be forwarded to SIEM immediately after generation. Local logs on servers are protected with access control, integrity checks, and restricted privileges. SIEM stores logs in append-only mode. Tampering attempts generate alerts to SOC.

Roles

- Security Engineer: Implements log protection mechanisms.
- SOC: Detects tampering.
- System Admin: Ensures local audit settings.

3.22. Audit Logging Requirements

Purpose

To define mandatory logging requirements for all systems.

4.24.2 Procedure

The following must be logged:



A handwritten signature in blue ink, appearing to be 'V. A.' or similar, located at the bottom right of the page.

- Authentication events
- Privileged access
- File access to sensitive data
- Network security events
- Firewall rule changes
- Database queries involving sensitive data
- System startup/shutdown
- Application activity
- Configuration changes

SOC Analysts review critical events daily; the Security Manager check daily and review weekly summaries.

3.23. Information Security & Governance

Purpose

To ensure cybersecurity standards, and procedures are properly maintained, reviewed, and communicated across the Bank.

Procedure

The Security Manager shall maintain the Bank's Information Security procedure suite, ensuring proper version control and publication. Procedures must be reviewed annually or after significant organizational or technological changes. Updated procedure must be communicated to all affected staff.

Roles

- Security Manager: Maintains and updates security procedures.
- CIO: Review updates on procedure and recommends for approval
- CEO: Approves major procedure changes.



[Handwritten signature]

3.24.Human Resources Security

Purpose

To ensure employees understand their security responsibilities and that risks associated with personnel are minimized.

Procedure

HR and the Security Manager shall ensure security roles and responsibilities are defined during hiring. Mandatory security training must be completed before system access is granted. HR must notify IT teams/Application support and administration immediately of employee role changes or termination. Staff with privileged access shall undergo enhanced background and periodic checks.

Roles

- HR: Oversees onboarding/offboarding notifications.
- Application support and administration: Proper action taken based on HR notification about employee
- Security Manager: Ensures security training.

3.25.Software Asset & License Management

Purpose

To maintain accurate visibility of all software assets and ensure only authorized applications are installed.

Procedure

System Administrators shall maintain a centralized inventory of installed software. All software must be licensed, approved, and comply with security standards. Unauthorized software must be removed upon discovery. Quarterly software inventory reviews must be conducted and discrepancies resolved.



A handwritten signature in blue ink, appearing to be 'J. A.', located at the bottom right of the page.

Roles

- System Administrator: Maintains software inventory.
- Security Manager: Reviews unauthorized software findings and recommend actions to be taken.

3.26. Secure Disposal & Media Handling

Purpose

To ensure secure disposal and sanitization of information bearing media and decommissioned equipment.

Procedure

Storage devices must be sanitized using approved methods such as cryptographic erase, multi-pass overwrite, or physical destruction. Disposal records must be maintained, including asset details and the method of destruction. Removable media usage must be restricted and encrypted where permitted.

Roles

- System Administrator: Performs device sanitization.
- Security Manager: Approves disposal methods.

3.27. Segregation of Duties (SoD)

Purpose

To prevent fraud, abuse, or system misuse by ensuring critical functions are divided among different individuals.

Procedure

All access requests must be reviewed for potential SoD conflicts. Conflicting access combinations require justification and approval from IS head/ CIO. Semi Annual SoD reviews must be conducted to ensure privileges remain appropriate.



Roles

- Security Manager: Reviews SoD.
- Application support : Prepare conflicting access
- CIO: Approve exceptions

3.28. Penetration Testing & Red Teaming

Purpose

To identify weaknesses in applications, infrastructure, and controls through simulated attacks and penetration testing.

Procedure

The Security Manager shall coordinate periodic internal and external penetration tests for critical systems. Annual red-team exercises must be conducted to validate detection and response capabilities. All findings must be documented and remediated before system rollout.

Roles

- Security Engineer: Supports testing and retesting.
- Security Manager: Prepare scope and reports.
- CIO: Approve

3.29. Application Whitelisting & Execution Control

Purpose

To prevent unauthorized or malicious applications from running on Bank systems.

Procedure

System Administrators shall implement allow listing on workstations and servers. Only approved applications may execute. Requests for new applications must be reviewed by the Security Manager. Allow list rules shall be reviewed quarterly.



Roles

- System Administrator: Implements and maintains allow lists.
- Security Manager: Approves new application requests.

3.30. Insider Threat Management

Purpose

To detect, prevent, and respond to risks posed by malicious or negligent insiders.

Procedure

The Security Manager shall operate an insider threat monitoring program combining behavioral analytics, DLP alerts, privileged access monitoring, and HR intel. High-risk indicators must be escalated immediately to CIO, then HR and Legal for investigation.

Roles

- Security Manager: Manages insider threat program.
- HR & Legal: Support investigations.

3.31. Secure Coding & Software Composition Analysis (SCA)

Purpose

To ensure internally developed and vendor-provided applications follow secure development standards.

Procedure

Applications must follow secure coding guidelines and OWASP best practices. All builds must undergo static analysis, SCA scanning, and vulnerability testing before deployment. Critical findings must be resolved prior to release.

Roles



- Application Developers/Vendors: Aling with standard as per the procedure while developing and Fix vulnerabilities.
- Security Engineer: Performs SAST/SCA scans.

3.32.Capacity & Performance Management

Purpose

To ensure adequate technical resources are available to support secure and uninterrupted banking operations.

Procedure

Infrastructure teams shall maintain capacity plans for compute, storage, and network resources. Quarterly capacity reviews must be conducted. Resource shortages or risks must be escalated to the CIO for budgeting and planning.

Roles

- System Administrator: Tracks server and storage capacity.
- Network Engineer: Tracks bandwidth and utilization.

3.33.Security Metrics & KPI Reporting

Purpose

To measure cybersecurity effectiveness and support decision-making.

Procedure

The SOC shall track and report KPIs such as detection time, response time, patch compliance, endpoint protection health, and incident trends.

Roles

- SOC Manager/Analysts: Generate KPIs.
- Security Manager: Prepares reports.



WA

3.34. Privacy Impact Assessment (PIA)

Purpose

To ensure personal and sensitive data is processed lawfully and securely.

Procedure

Any new service, product, or vendor involving personal data must undergo a Privacy Impact Assessment prior to approval. Data retention, consent, and processing rules must be documented and enforced.

Roles

- Security Manager: Leads PIA assessment.

3.35. Data Retention, Archiving & Legal Hold

Purpose

To ensure controlled retention and preservation of data for business, regulatory, and legal needs.

Procedure

Retention schedules must be applied to all data types. Sensitive data must be archived securely. System Administrators ensure retention settings align with policy or procedure and retention period set by financial industry regulatory organ.

Roles

- Security Manager: Maintains retention rules.
- System Administrator: Implements retention controls.



[Handwritten signature]

3.36.Audit & Compliance Testing

Purpose

To ensure ongoing compliance with cybersecurity procedures and regulatory expectations.

Procedure

All findings must be logged, tracked, and remediated. Security evidence (logs, test reports, configurations) must be retained for audit.

Roles

- Security Manager: Coordinates audits and remediation.
- Internal Audit: Performs independent checks.



PART-IV: PROCEDURE MANAGEMENT AND EXCEPTIONS

EXCEPTIONS

The CEO shall approve exception to this Procedure.

ENFORCEMENT

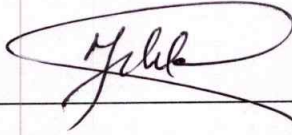
Violation of this Procedure may result in administrative and disciplinary measures. As per the banks human resources policy and procedure.

REVISION

This Procedure shall be reviewed and updated every two years or as deemed necessary, depending on changes in technology or regulatory requirements.

EFFECTIVE DATE

This Procedure approved on 11-11-2025 and it shall be effective immediately.



Melika Bedri

Chief Executive Officer



ANNEX I - DEFINITION OF TERMS

Access Control

A security mechanism that regulates who can view or use system resources based on approved permissions.

Administrative Session

A privileged system session used by administrators to configure, maintain, or monitor IT systems, recorded for audit and security monitoring.

Ad-hoc Report

A one-time or unscheduled report generated based on a specific information request, not part of regular reporting cycles.

Application Programming Interface (API)

A standardized interface that allows software systems to communicate, exchange data, and perform integrated functions.

Asset Classification

The process of categorizing information assets (e.g., Confidential, Restricted, Internal, Public) based on their sensitivity and criticality.

Audit Logging

The recording of system events and security-relevant activities to support monitoring, investigations, and compliance.

Authentication

The process of verifying the identity of a user, system, or device accessing Bank systems.

Authorization

The process that determines what actions a verified user or system is allowed to perform.



A handwritten signature in blue ink, consisting of stylized, overlapping loops and strokes.

Backup

A secure copy of data or system configurations stored for the purpose of recovery in case of failure, corruption, or cyberattack.

Business Continuity Plan (BCP)

A documented framework outlining how essential business operations will continue during and after a disruption.

Change Management

A formal process used to control modifications to IT systems, applications, configurations, or environments to minimize risks.

Configuration Management Database (CMDB)

A central repository storing details of hardware, software, network devices, and related configuration items.

Cryptographic Key

A mathematical value used in encryption and decryption processes to secure data.

Cyber Incident

Any event that compromises, or attempts to compromise, the confidentiality, integrity, or availability of systems or data.

Data Classification

A process that assigns sensitivity levels to information to determine how it must be protected.

Data Loss Prevention (DLP)

A technology that monitors, detects, and prevents unauthorized access, transfer, or exposure of sensitive data.

Disaster Recovery (DR)

A set of procedures enabling the restoration of IT services after major failures, disruptions, or cyberattacks.



Handwritten signature or initials.

Endpoint

Any user or computing device that connects to the Bank's network, such as desktops, laptops, mobile devices, or tablets.

Encryption

A method of converting readable data into an unreadable format to prevent unauthorized access.

Firewall

A security device or software that filters network traffic based on predefined security rules.

Identity & Access Management (IAM)

A set of processes and technologies used to manage digital identities and control user access to systems.

Incident Response

Coordinated activities performed to detect, analyze, contain, eradicate, and recover from cybersecurity incidents.

Intrusion Detection/Prevention System (IDS/IPS)

A monitoring system that identifies or blocks suspicious activities within the network.

Key Rotation

The scheduled process of replacing cryptographic keys to reduce security risk.

Log Retention

Defines how long system and security logs must be stored for audit, monitoring, or regulatory purposes.

Malware

Malicious software designed to damage, disrupt, or gain unauthorized access to systems.



VA

Multi-Factor Authentication (MFA)

An authentication method that requires two or more verification factors before granting access.

Network Segmentation

The practice of dividing a network into smaller, isolated zones to reduce risk and limit unauthorized access.

Patch

A software update designed to fix security vulnerabilities or operational issues.

Penetration Testing

A simulated attack conducted to identify vulnerabilities in systems, networks, or applications.

Privileged Access

Elevated permissions that allow users to perform administrative or sensitive actions on systems.

Privileged Access Management (PAM)

A security solution that manages and monitors privileged accounts and administrative sessions.

Recovery Point Objective (RPO)

The maximum acceptable amount of data loss measured in time.

Recovery Time Objective (RTO)

The maximum acceptable duration required to restore a system or service after a failure.

Security Information and Event Management (SIEM)

A centralized platform that collects, correlates, and analyzes logs to detect security incidents.



[Handwritten signature]

Secure Configuration / Hardening

The process of configuring systems using best-practice standards to minimize vulnerabilities and attack surfaces.

Software Composition Analysis (SCA)

The practice of scanning software code to identify vulnerabilities in third-party components and libraries.

Static / Dynamic Application Security Testing (SAST/DAST)

Security testing tools used to detect vulnerabilities in applications during development or runtime.

Threat Intelligence

Information about emerging or existing cyber threats that helps improve detection, response, and defense strategies.

Virtual Private Network (VPN)

A secure, encrypted communication channel used for remote access to Bank systems.

Vulnerability

A weakness in systems, applications, or controls that can be exploited by a threat actor.

Zero Trust

A security model that requires continuous verification of all users, devices, and systems, regardless of location.

SPF (Sender Policy Framework)

A security protocol that tells mail servers which IP addresses or mail servers are allowed to send email for your domain. It helps prevent email spoofing.

DKIM (DomainKeys Identified Mail)

A security method where emails are sent with a digital signature that can be verified using a public key in DNS. It ensures the email was not changed and was sent by an authorized sender.

DMARC (Domain-based Message Authentication, Reporting, and Conformance)

A security policy that tells receiving mail servers what to do when SPF or DKIM checks fail (do nothing, send to spam, or reject). It also sends reports about who is trying to use your domain.



ANNEX II – ACRONYMS

Acronym	Full Meaning
APIs	Application Programming Interfaces
CMDB	Configuration Management Database
SOC	Security Operations Center
MFA	Multi-Factor Authentication
PAM	Privileged Access Management
SIEM	Security Information and Event Management
IDS/IPS	Intrusion Detection System / Intrusion Prevention System
VLANs	Virtual Local Area Networks
CIS	Center for Internet Security
DISA	Defense Information Systems Agency
STIGs	Security Technical Implementation Guides
EDR	Endpoint Detection and Response
DLP	Data Loss Prevention
DR	Disaster Recovery
BCP	Business Continuity Plan
RTO	Recovery Time Objective
RPO	Recovery Point Objective
HR	Human Resources
CIO	Chief Information Officer
CTO	Change Ticket Owner (<i>as used in your text</i>)
CCTV	Closed-Circuit Television
UPS	Uninterruptible Power Supply
SWIFT	Society for Worldwide Interbank Financial Telecommunication
SAST/DAST	Static Application Security Testing / Dynamic Application Security Testing
SCA	Software Composition Analysis
OWASP	Open Web Application Security Project
MDM	Mobile Device Management
BYOD	Bring Your Own Device
KPI	Key Performance Indicator
PIA	Privacy Impact Assessment
VPN	Virtual Private Network
AIX	Advanced Interactive eXecutive (<i>IBM UNIX OS</i>)
SPF	Sender Policy Framework
DKIM	DomainKeys Identified Mail
DMARC	Domain-based Message Authentication, Reporting, and Conformance



[Handwritten signature]